

Test Report — only an account may change the database

PR: kuantorflow#182 + kuantorflow_automation#40 · Issue: kuantorflow#125 · Date: 2026-08-02

Summary

Writing a card now requires a signed-in account on every path that writes one; reading stays open to anyone past the keyword gate. Verified in the browser on both refusal paths — nothing reached the database, and the prompt named the way out. **388 offline tests pass** (was 370), including four ownership tests rewritten because their subject — the unowned card — no longer exists.

What changed

- ``can_add_cards()`` in `app.py` — signed in *and* carrying a users-row id. A sign-in whose row could not be written (#148) is refused: an unowned card cannot be deleted by the person who added it (#162), so the failure is taken in the safe direction.
- ``_save_and_log()`` enforces it, being the single funnel every save path already goes through (#89 records the owner there). A save path that forgets to ask raises instead of quietly writing.
- **Three entry points answer a person:** POST `/cards/add` returns 403 {ok: false, sign_in_required: true, error: ...}; the automatic-add path keeps the looked-up cards in the review popup and raises the prompt on load; Mykola's card_saver raises, and ai_agent relays that as an error the model explains rather than claiming a card it never saved.
- **The dialog** lives in `base.html` behind `window.kfSignInRequired()`, so any page can raise it — #126's blocked-account refusal can reuse it.
- ``applog.card_add_denied()`` writes ADD-DENIED, the counterpart to #162's DELETE-DENIED.
- Nothing is greyed out or hidden. That reading of the issue was chosen deliberately: the routes refuse, and a hand-made POST gets the same answer.

Automated tests

- **Added:** `tests/test_anonymous_writes.py` — the refusal on all three write paths, the funnel enforcing it with no route involved, the refusal landing *before* the duplicate check (a refused card must never be reported as "already in the database"), the ADD-DENIED line, the sign-in link being real, POST `/settings` still answering with #102's own 403, and the read paths staying open.
- **Rewritten:** four tests in `test_card_ownership.py` whose subject was the unowned card the app no longer produces — an anonymous popup save, the anonymous automatic add, a sign-in with no users row, and a dropped pre-#148 session. Each now asserts the refusal. The NULL-owner storage path is still covered directly against `utils`, which keeps it for the maintenance scripts and for rows predating #89.

- **Migrated to `user\_client`:** the remaining saves in `test_action_logs.py`, `test_lookup_and_cards.py` and `test_duplicates.py` — the same migration #102 forced on the settings tests.
- **Suite result:** `pytest -m "not live"` — **388 passed, 6 skipped** (was 370 passed, 6 skipped).

Manual & browser verification

Anonymous, against local MySQL, at 1280×720 and then 375×812.

- Looked up *resilient* → the lookup succeeded and the review popup offered the card, confirming reading is untouched.
- Clicked **Add** → POST `/cards/add` returned **403** on the wire; the dialog read *"Please sign in with Google to make any changes of the database."* with a **Sign in with Google** link pointing at `/login/google`; no console errors; the Add button reset to "Add" rather than sticking on "Adding..."
- Queried the database directly: **no row for `resilient`**. `cards.log` gained `ADD-DENIED word=resilient pos=adjective topic=general reason=anonymous source='review popup' user=anonymous`.
- Turned *Add cards automatically* on in the anonymous default config, looked up *brittle* → the prompt appeared **on page load**, the two looked-up cards were waiting in the review popup behind it, nothing was written, and `ADD-DENIED ... source='automatic add'` was logged. The config file was restored afterwards.
- Mobile (375×812): the dialog measured 338px inside the viewport with no horizontal overflow, and the sign-in link was a 175×60 tap target.
- Cleanup: no test rows written (none could be), config restored, dev server stopped.

Result

Pass. Every write path an anonymous visitor can reach is refused by its route, the refusal is explained where the attempt happened, and nothing reached the database in any of the checks.

Not covered here, deliberately:

- **The signed-in half is covered by tests, not the browser** — it needs a real Google round trip. `user_client` asserts a save still returns `{"ok": true, "saved": true}` and records the owner.
- **Mykola's refusal was exercised at the `card\_saver` boundary**, not by chatting to a live agent; what `ai_agent` does with the exception is its own tested behaviour.
- **#126** will reuse `window.kfSignInRequired()` for a blocked account, which is why the dialog takes an optional message.